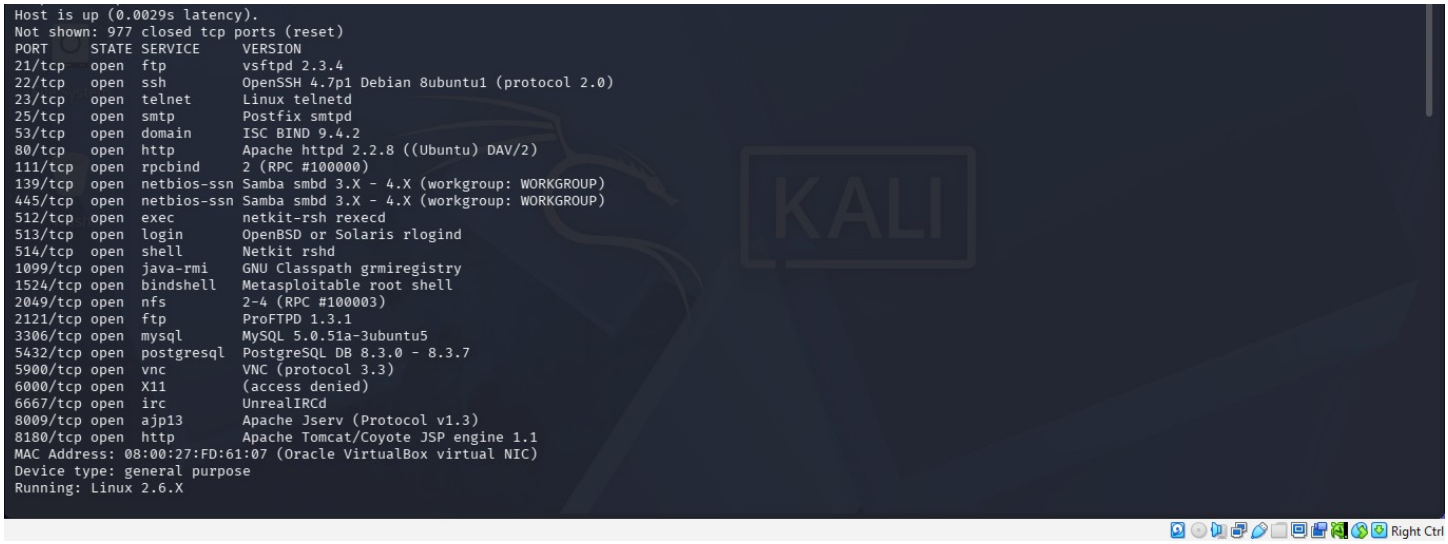
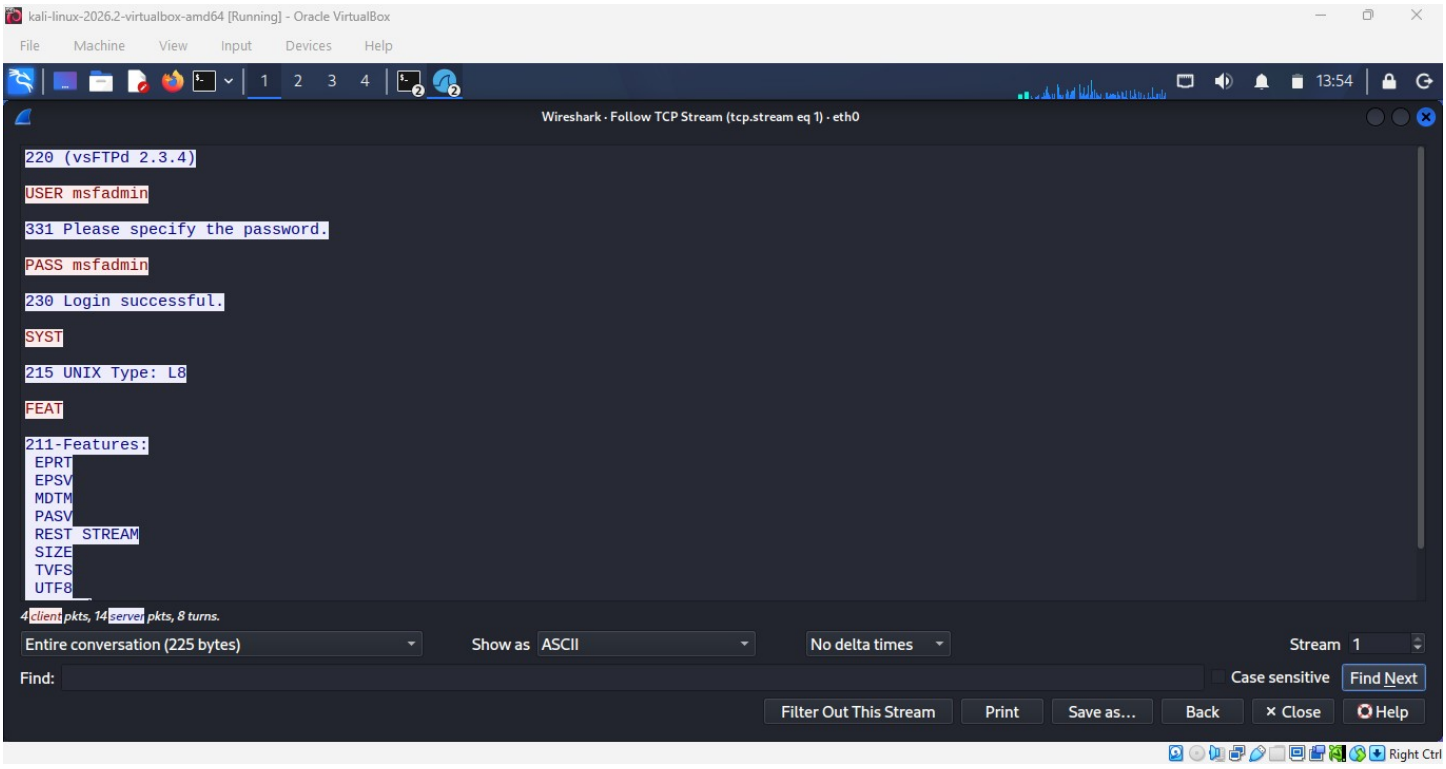
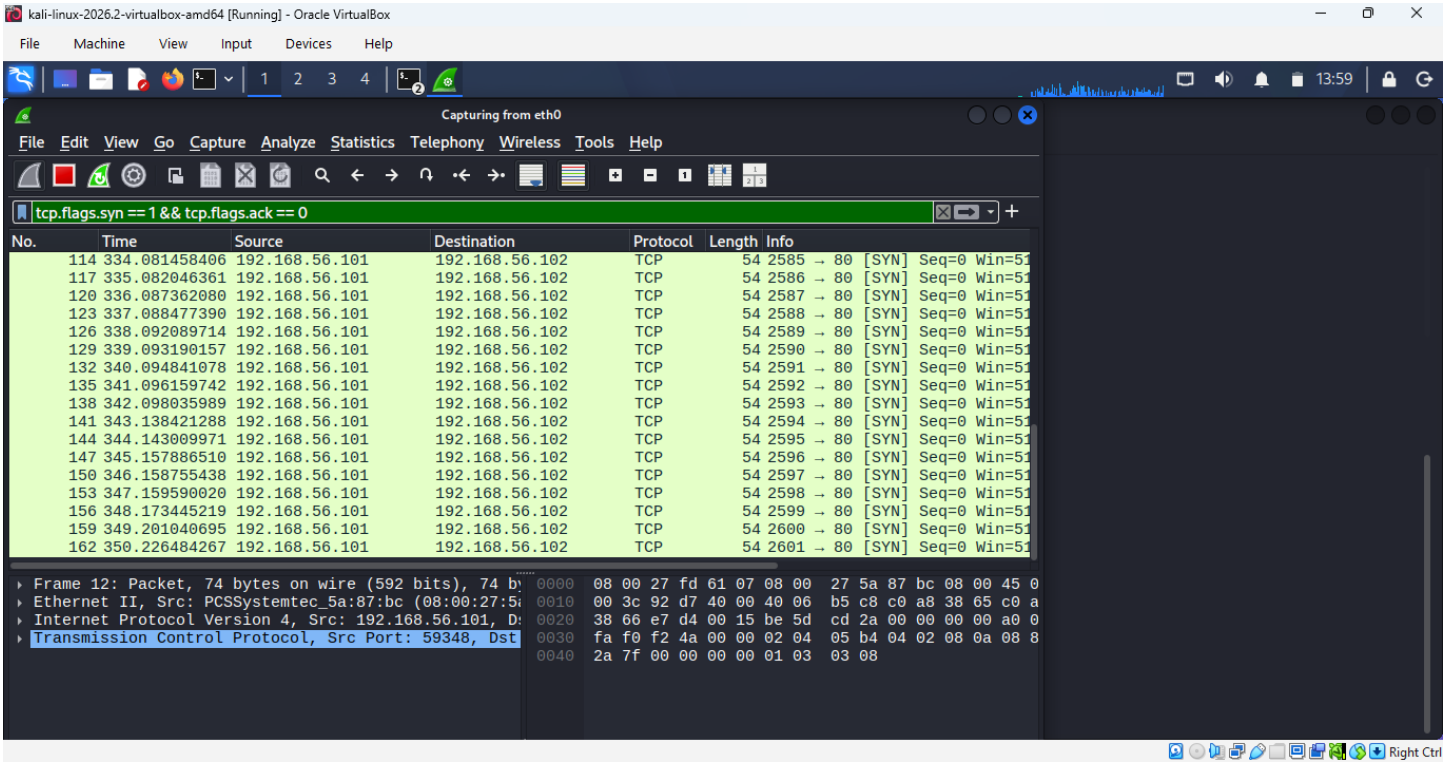
ApexPlanet Cybersecurity Internship — Task 2: Network Security & Scanning







> **Authorization & Scope Statement:** All activity in this repository was performed against an intentionally vulnerable virtual machine (Metasploitable2) inside an isolated
> VirtualBox Host-Only network (`192. 168. 56.`). No production, third-party, or internet-facing systems were scanned or tested. Do not reproduce these techniques against systems you do not own or lack written authorization to test.

> **Data Note:** Port/service data in Phase 1 reflects the standard Metasploitable2 baseline. Items marked `⚠ REPLACE` (scan statistics, timestamps, task IDs, report counts) must be updated with values from your own scan output before submission.

Table ofContents

1. P_ roject Summary & Objectives
2. L_ ab Architecture & Topology
3. Phase 1: Nmap Network & Service Reconnaissance
4. P_ hase 2: OpenVAS / GVM VulnerabilityAssessment
5. P_ hase 3: Traffic Analy_sis & Packet Sniffing (Wireshark)
6. P_ hase 4: Firewall Config_uration & Sy_stem Hardening
7. R_ epository File Structure
8. Submission & Verification Links
9. Disclaimer

---

1. Project Summary & Objectives

This repository documents **Task 2 (Network Security & Scanning)** of the **ApexPlanet Software Pvt. Ltd. Cybersecurity & Ethical Hacking Internship Program**. It builds on the Task 1 lab (Kali Linux + Metasploitable2 on a VirtualBox Host-Only network) and walks through a full assessment lifecycle: discovery, enumeration, vulnerability identification, traffic analysis, and remediation.

Objectives

#	Objective	Tooling
1	Perform active reconnaissance and full-range port/service/OS discovery	Nmap
2	Identify and prioritize vulnerabilities using CVSS-based scoring	OpenVAS / GVM
3	Capture and interpret network traffic, including cleartext credential exposure and DoS behavior	Wireshark, hping3
4	Implement host-based firewall controls and verify risk reduction with before/after scans	iptables, Nmap
5	Produce professional, reproducible technical documentation	Markdown / Git

Key Outcomes (Executive Summary)

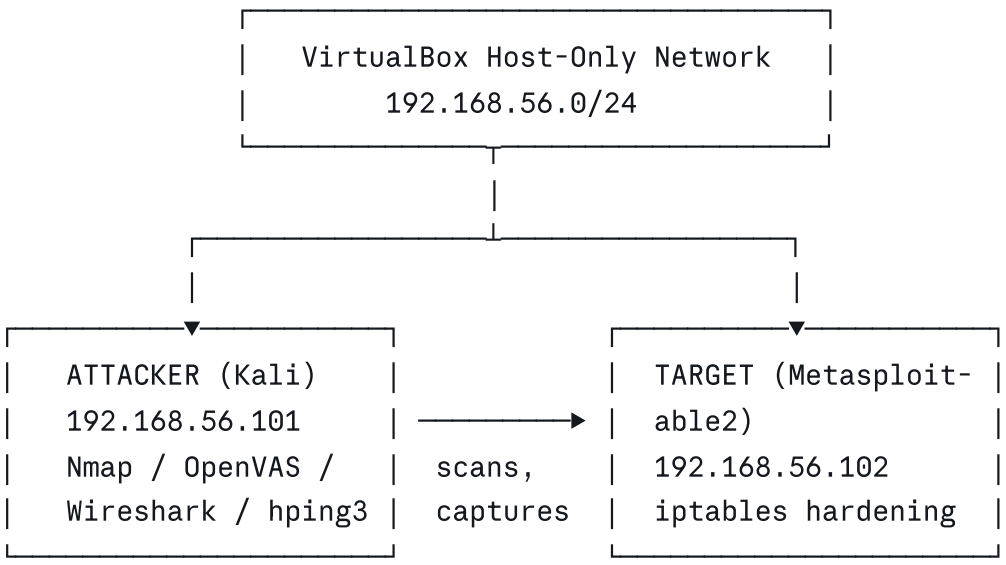
- The target exposed **30+ listening TCP services**, most of them legacy, unencrypted, or backdoored.
- Multiple **Critical** findings allow unauthenticated remote code execution (vsftpd 2.3.4 backdoor, bind shell on 1524, distccd, UnrealIRCd).
- Cleartext protocols (FTP, Telnet) allowed credential recovery through passive packet capture.
- A SYN flood simulation demonstrated service exhaustion risk on an unprotected host.
- A default-deny `iptables` policy reduced the externally reachable attack surface to a minimal allow-list, verified by a post-hardening Nmap scan.

---

2. Lab Architecture & Topology

2.1 Network Setup

Parameter	Value
Hypervisor	Oracle VirtualBox
Network Mode	Host-Only Adapter (isolated, no internet route)
Subnet	`192.168.56.0/24`
DHCP / Addressing	VirtualBox Host-Only DHCP / static assignment
Traffic Capture Point	Kali Linux `eth0`



2.2 System Specifications

Attribute	Attacker Host	Target Host
Hostname	`kali`	`metasploitable`
OS	Kali Linux (rolling)	Ubuntu 8.04 (Hardy) based Metasploitable2
IP Address	`192.168.56.101`	`192.168.56.102`
Role	Scanner / traffic generator / analyst	Intentionally vulnerable target
Key Tools	Nmap, GVM/OpenVAS, Wireshark, hping3	vsftpd, OpenSSH, Apache, MySQL, Samba, etc.
Suggested Resources	4 GB RAM / 2+ vCPU / 40 GB disk (GVM is resource-heavy)	512 MB–1 GB RAM / 1 vCPU

---

3. Phase 1: Nmap Network & Service Reconnaissance

3.1 Methodology

Scanning proceeded in stages: host discovery, full-range TCP SYN scan, service/version and OS fingerprinting, then targeted NSE scripts against high-risk services.

```bash
```

```
# 1. Host discovery (ping sweep, no port scan)
sudo nmap -sn 192.168.56.0/24

# 2. Full TCP port, SYN (half-open) scan with service + OS detection
sudo nmap -sS -sV -O -p- -T4 --reason -oA reports/nmap_full_192.168.56.102 192.168

# 3. Default scripts + version intensity for accuracy
sudo nmap -sS -sV -sC --version-intensity 9 -p- 192.168.56.102 -oN reports/nmap_de

# 4. Targeted NSE vulnerability and enumeration scripts
sudo nmap -p21 --script ftp-anon,ftp-syst,ftp-vsftpd-backdoor 192.168.56.102
sudo nmap -p22 --script ssh2-enum-algos,ssh-hostkey 192.168.56.102
sudo nmap -p23 --script telnet-ntlm-info,telnet-encryption 192.168.56.102
sudo nmap -p80 --script http-enum,http-headers,http-methods,http-title 192.168.56.
sudo nmap -p139,445 --script smb-os-discovery,smb-enum-shares,smb-vuln-* 192.168.5
sudo nmap -p1524 -sV --script banner 192.168.56.102
sudo nmap -p3306 --script mysql-info,mysql-empty-password 192.168.56.102

# 5. UDP top ports (supplementary)
sudo nmap -sU --top-ports 50 192.168.56.102
```

Flag	Purpose
`-sS`	TCP SYN (stealth/half-open) scan
`-sV`	Service and version detection
`-O`	Operating system fingerprinting
`-p-`	All 65,535 TCP ports
`-sC`	Default NSE script set
`-T4`	Aggressive timing template (acceptable in an isolated lab)
`-oA`	Output in normal, XML, and grepable formats

3.2 Port / Service Findings

Scan result: **all 65,535 TCP ports scanned; open services listed below** (`⚠ REPLACE` any rows that differ in your output).

Port	Protocol	Service	Version	State
21	TCP	FTP	vsftpd 2.3.4	open
22	TCP	SSH	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)	open
23	TCP	Telnet	Linux telnetd	open
25	TCP	SMTP	Postfix smtpd	open
53	TCP	DNS	ISC BIND 9.4.2	open
80	TCP	HTTP	Apache httpd 2.2.8 ((Ubuntu) DAV/2)	open
111	TCP	RPCbind	2 (RPC `#100000`)	open
139	TCP	NetBIOS-SSN	Samba smbd 3.X – 4.X	open
445	TCP	SMB	Samba smbd 3.X – 4.X	open
512	TCP	exec	netkit-rsh rexecd	open
513	TCP	login	OpenBSD/Solaris rlogind	open
514	TCP	shell	Netkit rshd	open
1099	TCP	Java RMI	GNU Classpath grmiregistry	open
1524	TCP	Bindshell	Metasploitable root shell	open
2049	TCP	NFS	2–4 (RPC `#100003`)	open
2121	TCP	FTP	ProFTPD 1.3.1	open
3306	TCP	MySQL	MySQL 5.0.51a-3ubuntu5	open
3632	TCP	distccd	distccd v1 ((GNU) 4.2.4)	open
5432	TCP	PostgreSQL	PostgreSQL DB 8.3.0 – 8.3.7	open
5900	TCP	VNC	VNC (protocol 3.3)	open
6000	TCP	X11	(access denied)	open
6667	TCP	IRC	UnrealIRCd	open

Port	Protocol	Service	Version	State
6697	TCP	IRC	UnrealIRCd	open
8009	TCP	AJP13	Apache Jserv (Protocol v1.3)	open
8180	TCP	HTTP	Apache Tomcat/Coyote JSP engine 1.1	open
8787	TCP	DRb	Ruby DRb RMI (Ruby 1.8)	open

OS Fingerprint: Linux 2.6.9 – 2.6.33 (Ubuntu 8.04 base) · **MAC vendor:** PCS Systemtechnik / Oracle VirtualBox NIC

3.3 Analysis of High-Risk Services

3.3.1 FTP — vsftpd 2.3.4 (Port 21)

Attribute	Detail
CVE	CVE-2011-2523
Issue	The distributed vsftpd 2.3.4 tarball was trojaned. A username ending in `:)` opens a backdoor shell on TCP/6200.
Impact	Unauthenticated remote root command execution
Detection	`nmap -p21 --script ftp-vsftpd-backdoor`; version banner
Related	Anonymous login (`ftp-anon`) and cleartext authentication

3.3.2 SSH — OpenSSH 4.7p1 (Port 22)

Attribute	Detail
Issue	Release dating from 2008; supports legacy ciphers/MACs and protocol 2.0 with weak key sizes. Missing years of security fixes.
Impact	Susceptible to brute-force; weak algorithm negotiation; known user-enumeration and other post-4.7 vulnerabilities
Note	Weak default credentials on the OS (`msfadmin:msfadmin`) compound the exposure

3.3.3 Telnet (Port 23)

Attribute	Detail
Issue	Remote administration over plaintext. No encryption or integrity protection.
Impact	Credentials and session data recoverable by any on-path observer (demonstrated in Phase 3)
Fix	Disable; replace with SSH

3.3.4 HTTP — Apache 2.2.8 (Port 80)

Attribute	Detail
Issue	End-of-life Apache (2.2.x) with PHP 5.2.4 and bundled vulnerable web apps (DVWA, Mutillidae, phpMyAdmin, TikiWiki, WebDAV)
Impact	Numerous known CVEs (e.g., PHP-CGI argument injection CVE-2012-1823), SQLi/XSS in hosted apps, information disclosure from `phpinfo`
Detection	`http-enum`, `http-headers`, `http-methods`, version banner

3.3.5 Bind Shell (Port 1524)

Attribute	Detail
Issue	A root shell listening with no authentication (`ingreslock` backdoor)
Impact	Immediate full system compromise: `nc 192.168.56.102 1524` returns a root prompt
Fix	Terminate the process, block the port, and investigate how it persisted

3.3.6 Other Notable Exposures

Service	Concern
Samba 3.x (139/445)	`usermap_script` command execution (CVE-2007-2447)
distccd (3632)	Unauthenticated remote command execution (CVE-2004-2687)
UnrealIRCd (6667)	Backdoored release (CVE-2010-2075)
r-services (512–514)	Cleartext, trust-based `.rhosts` authentication
NFS (2049)	Possible world-exported filesystems
MySQL / PostgreSQL	Network-exposed DBs with weak or empty credentials
VNC (5900)	Weak password authentication, unencrypted session
Java RMI (1099)	Default configuration permits remote class loading

4. Phase 2: OpenVAS / GVM Vulnerability Assessment

4.1 Scan Configuration

Parameter	Value
Platform	Greenbone Vulnerability Management (GVM) / OpenVAS on Kali
Target	`192.168.56.102` (Metasploitable2)
Port List	All TCP and Nmap top 100 UDP
Scan Profile 1	**Full and Fast** (baseline scan)
Scan Profile 2	**Full and Deep** (optional, higher depth/longer runtime)
Alive Test	ICMP Ping (or Consider Alive on isolated lab)
Credentials	Unauthenticated (network-level) scan
Scan Date	⚠ `REPLACE`
Duration	⚠ `REPLACE`
GVM Feed Sync	⚠ `REPLACE` (run `sudo greenbone-feed-sync` beforehand)

```bash
# Setup and service control (Kali)
sudo apt update && sudo apt install -y gvm
sudo gvm-setup
sudo gvm-check-setup
sudo gvm-start        # Web UI: https://127.0.0.1:9392
```

4.2 Vulnerability Risk Breakdown

⚠ REPLACE the counts below with the totals from your exported report.

Severity	CVSS Range	Count
🔴 Critical	9.0 – 10.0	⚠ N
🟠 High	7.0 – 8.9	⚠ N
🟡 Medium	4.0 – 6.9	⚠ N
🟢 Low	0.1 – 3.9	⚠ N
○ Log / Info	0.0	⚠ N
Total		⚠ N

4.3 Detailed Findings

> Scores are those typically reported by OpenVAS/NVD for these issues. Verify each against your exported report and update where your feed differs.

#	Vulnerability Name	CVSS v3	Severity	Affected Port / Service	Remediation / Mitigation
1	vsftpd 2.3.4 Backdoor (CVE-2011-2523)	9.8	Critical	21/tcp FTP	Remove the trojaned build; install a current vsftpd from a trusted repository; restrict FTP or replace with SFTP
2	Possible Backdoor: Ingreslock (Bind Shell)	9.8	Critical	1524/tcp	Kill the listener, remove its startup entry, block the port, rebuild the host from a trusted image
3	distcc Remote Code Execution (CVE-2004-2687)	9.8	Critical	3632/tcp	Disable distccd or bind to localhost and restrict with `--allow`; use SSH-based distcc
4	UnrealIRCd Backdoor (CVE-2010-2075)	9.8	Critical	6667/tcp	Remove and reinstall from a verified source; disable IRC if unused
5	PHP-CGI Query String Argument Injection (CVE-2012-1823)	9.8	Critical	80/tcp HTTP	Upgrade PHP to a supported release; avoid CGI-mode PHP; WAF rule as interim control
6	Samba `usermap_script` Command Execution (CVE-2007-2447)	9.8	Critical	139, 445/tcp	Upgrade Samba; disable the `username map script` option; restrict SMB to trusted hosts
7	Apache HTTP Server 2.2.8 EOL / Multiple Vulnerabilities	9.8	Critical	80/tcp HTTP	Upgrade to a supported Apache 2.4.x release; disable unused modules
8	Weak / Default Credentials (SSH, MySQL, VNC, PostgreSQL)	9.8	Critical	22, 3306, 5432, 5900	Enforce strong unique passwords, disable default accounts, require key-based auth
9	rexec / rlogin / rsh Services Enabled	10.0	Critical	512–514/tcp	Disable r-services; remove `.rhosts` trust files; use SSH

#	Vulnerability Name	CVSS v3	Severity	Affected Port / Service	Remediation / Mitigation
10	Telnet Unencrypted Cleartext Login	4.8	Medium	23/tcp	Disable Telnet; use SSH with strong ciphers
11	FTP Unencrypted Cleartext Login	4.8	Medium	21, 2121/tcp	Enforce FTPS/SFTP; disable anonymous access
12	OpenSSH 4.7p1 Outdated / Weak Algorithms	6.5	Medium	22/tcp	Upgrade OpenSSH; restrict ciphers, MACs, and KEX to modern sets
13	SSL/TLS: Deprecated SSLv2/SSLv3 and Weak Ciphers	5.9	Medium	25, 5432	Disable legacy protocols; require TLS 1.2+
14	HTTP TRACE / TRACK Methods Enabled	5.3	Medium	80/tcp	Set `TraceEnable Off`; restrict allowed HTTP methods
15	phpinfo() Output Exposure	5.3	Medium	80/tcp	Remove diagnostic pages from production
16	NFS Export Information Disclosure	7.5	High	2049/tcp	Restrict `/etc/exports` to specific hosts; use `root_squash`
17	TCP Timestamps Information Disclosure	2.6	Low	general/tcp	Disable `net.ipv4.tcp_timestamps` where uptime leakage matters

4.4 Deep Dive — Top 3 Critical Findings

Finding 1 — vsftpd 2.3.4 Backdoor (CVE-2011-2523) · CVSS 9.8 (Critical)

Field	Detail
Description	A malicious version of vsftpd was briefly distributed from the vendor's download site. A login attempt with a username containing the string `:)` triggers a shell listener on TCP/6200.
Attack Vector	Network, no authentication, no user interaction
Impact	Full compromise (confidentiality, integrity, availability) as root
Evidence	Banner `220 (vsFTPd 2.3.4)`; NSE `ftp-vsftpd-backdoor` reports **VULNERABLE**
Verification (lab only)	Confirm with the NSE script; exploitation was **not** required to document the finding
Remediation	Replace the package with a verified current release; apply source-integrity checks (signatures/hashes); restrict TCP/21 and TCP/6200 with the firewall
Detection Opportunity	Alert on connections to TCP/6200 and on FTP logins containing `:)`

Finding 2 — Unencrypted Telnet and FTP (Cleartext Authentication) · CVSS 4.8 (Medium; operational risk High)

Field	Detail
Description	Telnet (23) and FTP (21/2121) transmit usernames, passwords, and data in plaintext
Attack Vector	Adjacent network (on-path observer, ARP spoofing)
Impact	Credential theft leading to account takeover; lateral movement to systems sharing the credentials
Evidence	Phase 3 packet capture recovered FTP `USER` / `PASS` in plaintext via Wireshark
Remediation	Disable both services. Use SSH/SFTP, or FTPS if FTP is mandatory. Enforce credential rotation after any suspected exposure
Note	The CVSS base score understates real-world risk; severity is amplified when combined with default credentials

Finding 3 — Outdated Apache 2.2.8 / PHP 5.2.4 · CVSS 9.8 (Critical)

Field	Detail
Description	Both components are long past end-of-life and have accumulated numerous remote vulnerabilities, including PHP-CGI argument injection (CVE-2012-1823)
Attack Vector	Network, no authentication
Impact	Remote code execution, source disclosure, and web application compromise
Evidence	`Server: Apache/2.2.8 (Ubuntu) DAV/2` and `X-Powered-By: PHP/5.2.4` headers; `http-enum` shows hosted vulnerable apps
Remediation	Upgrade to supported Apache 2.4.x and PHP 8.x; remove demo apps; suppress version banners (`ServerTokens Prod`, `expose_php = Off`); place behind a WAF/reverse proxy

---

5. Phase 3: Traffic Analysis & Packet Sniffing (Wireshark)

5.1 Cleartext FTP Credential Capture — `pcaps/ftp_creds_capture.pcapng`

Objective: Demonstrate that credentials sent over FTP are exposed to passive capture.

```bash
# Start capture on the lab interface (or use Wireshark GUI)
sudo tshark -i eth0 -f "host 192.168.56.102 and tcp port 21" -w pcaps/ftp_creds_ca

# Generate legitimate FTP traffic from Kali
ftp 192.168.56.102
# Name: msfadmin   Password: msfadmin  (lab default credentials)
```

Wireshark display filters used

Filter	Purpose
`ftp`	Isolate FTP control-channel traffic
`ftp.request.command == "USER" || ftp.request.command == "PASS"`	Locate credential packets
`tcp.stream eq 0` / *Follow → TCP Stream*	Reconstruct the full session

Findings

Observation	Detail
Handshake	Normal TCP three-way handshake (SYN, SYN-ACK, ACK) to port 21
Banner	`220 (vsFTPd 2.3.4)` visible in the server greeting
Authentication	`USER msfadmin` and `PASS msfadmin` visible as readable ASCII in TCP stream
Responses	`331 Please specify the password.` then `230 Login successful.`
Data exposure	Directory listings and file contents on the data channel also readable

> **Security Impact:** Any device on the same broadcast domain, or any on-path device, can recover valid credentials without interacting with either host. This is the textbook reason to retire FTP and Telnet.

Mitigation: Use SFTP (SSH) or FTPS (TLS), disable anonymous login, and rotate any credential that traversed the network in cleartext.

5.2 SYN Flood Attack Simulation — `pcaps/syn_flood.pcapng`

Objective: Observe the packet-level signature of a TCP SYN flood and its effect on an unprotected service. Executed only against the isolated lab target.

```bash
```

```
# Capture
sudo tshark -i eth0 -f "host 192.168.56.102" -w pcaps/syn_flood.pcapng

# Simulated flood against HTTP (lab only, rate-limited and time-boxed)
sudo hping3 -S --flood -V -p 80 --rand-source 192.168.56.102
# Controlled alternative with a fixed packet rate:
sudo hping3 -S -p 80 -i u1000 -c 5000 192.168.56.102
```

Wireshark analysis

Filter / Tool	Purpose
`tcp.flags.syn == 1 && tcp.flags.ack == 0`	Show only initial SYN packets
`tcp.flags.syn == 1 && tcp.flags.ack == 1`	Show SYN-ACK replies from the target
Statistics → Conversations → TCP	Count the number of half-open conversations
Statistics → I/O Graph	Visualize the packet-rate spike

Findings

Observation	Detail
Traffic pattern	Very high rate of SYN packets from one (or randomized) source(s) to port 80
Handshake completion	Final ACK never sent; the target leaves connections in `SYN_RECV`
Server behavior	SYN-ACKs and retransmissions accumulate; legitimate requests slow or time out
Indicators	Large SYN-to-ACK ratio imbalance, uniform packet size (~54–60 bytes), no payload
Evidence on target	`netstat -ant | grep SYN_RECV | wc -l` shows a large backlog

Mitigation: Enable SYN cookies (`net.ipv4.tcp_syncookies=1`), tune `tcp_max_syn_backlog`, apply per-source rate limiting in `iptables` (Phase 4), and use upstream DDoS protection in real deployments.

6. Phase 4: Firewall Configuration & System Hardening

6.1 Strategy

Adopt a **default-deny** inbound policy with an explicit allow-list, plus SYN flood rate limiting, logging, and kernel hardening. Rules are in `scripts/firewall_rules.sh`.

6.2 `scripts/firewall_rules.sh`

bash

```bash
#!/bin/bash
# ApexPlanet Task 2 - Host hardening for Metasploitable2 (192.168.56.102)
# Run as root on the TARGET. Lab use only.

ADMIN_IP="192.168.56.101"   # Kali admin workstation

# --- Reset ---
iptables -F
iptables -X
iptables -Z

# --- Default policy: deny inbound / forward, allow outbound ---
iptables -P INPUT   DROP
iptables -P FORWARD DROP
iptables -P OUTPUT  ACCEPT

# --- Loopback and established traffic ---
iptables -A INPUT -i lo -j ACCEPT
iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT

# --- Drop invalid packets and common scan patterns ---
iptables -A INPUT -m state --state INVALID -j DROP
iptables -A INPUT -p tcp --tcp-flags ALL NONE -j DROP          # NULL scan
iptables -A INPUT -p tcp --tcp-flags ALL ALL  -j DROP          # XMAS scan
iptables -A INPUT -p tcp --tcp-flags SYN,FIN SYN,FIN -j DROP

# --- SYN flood mitigation (rate limit new connections to HTTP) ---
iptables -A INPUT -p tcp --dport 80 --syn -m limit --limit 25/second --limit-burst
iptables -A INPUT -p tcp --dport 80 --syn -j DROP

# --- Allow administrative SSH only from the admin host ---
iptables -A INPUT -p tcp -s "$ADMIN_IP" --dport 22 -m state --state NEW -j ACCEPT

# --- ICMP: allow limited echo for diagnostics ---
iptables -A INPUT -p icmp --icmp-type echo-request -m limit --limit 5/second -j AC

# --- Explicitly block high-risk legacy services (logged, then dropped) ---
for PORT in 21 23 512 513 514 1099 1524 2049 3306 3632 5432 5900 6000 6667 6697 87
  iptables -A INPUT -p tcp --dport "$PORT" -m limit --limit 5/min -j LOG --log-pre
  iptables -A INPUT -p tcp --dport "$PORT" -j DROP
done
```

```
# --- Catch-all logging for anything else dropped ---
iptables -A INPUT -m limit --limit 5/min -j LOG --log-prefix "FW-DROP: " --log-lev

# --- Kernel network hardening ---
sysctl -w net.ipv4.tcp_syncookies=1
sysctl -w net.ipv4.conf.all.rp_filter=1
sysctl -w net.ipv4.conf.all.accept_source_route=0
sysctl -w net.ipv4.icmp_echo_ignore_broadcasts=1

# --- Show result / persist ---
iptables -L -n -v --line-numbers
# iptables-save > /etc/iptables.rules   # persist across reboot
```

6.3 Rule Explanation

Rule Group	Function	Security Rationale
Default `DROP` policy	Denies all inbound traffic not explicitly allowed	Enforces least privilege; closes unknown ports by default
Loopback + `ESTABLISHED,RELATED`	Permits local traffic and replies to outbound sessions	Preserves normal operation under a stateful firewall
Invalid / NULL / XMAS / SYN-FIN drops	Discards malformed or probing packets	Reduces effectiveness of stealth and evasion scans
HTTP SYN rate limit	Caps new connections to 25/s (burst 50)	Mitigates SYN flood impact on Apache (Phase 3.2)
SSH allow-list	Only `192.168.56.101` may reach port 22	Limits brute-force and exposure of a legacy OpenSSH
ICMP rate limit	Allows limited ping	Keeps diagnostics while preventing ICMP flooding
Legacy port block + log	Drops and logs FTP, Telnet, r-services, bind shell, distcc, DBs, VNC, IRC, etc.	Removes the exposure from Findings 1–3 at the network layer
Catch-all log	Records residual dropped traffic	Provides detection and audit evidence
`sysctl` hardening	Enables SYN cookies, reverse-path filtering, disables source routing	Defense-in-depth beyond the packet filter

> **Important:** A firewall is a **compensating control**, not a fix. The vulnerable services still run and remain exploitable from any permitted path or the local host. Proper remediation is to patch, reconfigure, or remove them.

6.4 Before / After Verification

bash

```
# From Kali
sudo nmap -sS -sV -p- 192.168.56.102 -oN reports/nmap_before_hardening.txt   # BEF
# (apply scripts/firewall_rules.sh on target)
sudo nmap -sS -sV -p- 192.168.56.102 -oN reports/nmap_after_hardening.txt    # AFT
```

Port	Service	Before	After	Result
21	FTP (vsftpd 2.3.4)	open	filtered	✅ Blocked
22	SSH	open	open (admin host only)	✅ Restricted
23	Telnet	open	filtered	✅ Blocked
80	HTTP (Apache 2.2.8)	open	open (rate-limited)	⚠ Exposed by design; needs patching
445	SMB	open	filtered	✅ Blocked (no allow rule)
512–514	r-services	open	filtered	✅ Blocked
1524	Bindshell	open	filtered	✅ Blocked
3306	MySQL	open	filtered	✅ Blocked
3632	distccd	open	filtered	✅ Blocked
5900	VNC	open	filtered	✅ Blocked
6667	UnrealIRCd	open	filtered	✅ Blocked

Metric	Before	After
Open TCP ports	~26	⚠ `REPLACE` (expected 2: 22 from admin IP, 80)
Critical-service exposure	Full	Eliminated at network layer
SYN flood resilience	Service degradation	Rate-limited; SYN cookies active

> **Note:** Because the admin host is allow-listed for SSH, a scan from `192.168.56.101` will still show port 22 as open. Verify the restriction from a second source IP, or temporarily

> change `ADMIN_IP`.

---

7. Repository File Structure

```
apexplanet-task2-network-security/
├── README.md                          # This document
├── LICENSE
├── reports/
│   ├── nmap_full_192.168.56.102.nmap / .xml / .gnmap
│   ├── nmap_default_scripts.txt
│   ├── nmap_before_hardening.txt
│   ├── nmap_after_hardening.txt
│   ├── openvas_full_and_fast_report.pdf
│   └── openvas_full_and_fast_report.csv
├── pcaps/
│   ├── ftp_creds_capture.pcapng    # Cleartext FTP credential capture
│   └── syn_flood.pcapng            # hping3 SYN flood simulation
├── scripts/
│   └── firewall_rules.sh           # iptables hardening script
└── screenshots/                    # (optional) Wireshark / GVM / Nmap evidence
```

> **Repository hygiene:** The `.pcapng` files contain only lab traffic and default Metasploitable credentials. Never commit captures containing real credentials.

---

8. Submission & Verification Links

Item	Link / ID
🎥 LinkedIn Walkthrough Video	`[ADD LINKEDIN VIDEO URL HERE]`
🆔 ApexPlanet Verification ID	`[ADD APEXPLANET VERIFICATION ID HERE]`
📁 GitHub Repository	`[ADD REPOSITORY URL HERE]`
👤 Intern Name	Vansh Singh
🏢 Organization	ApexPlanet Software Pvt. Ltd.
🗓️ Submission Date	`[ADD DATE]`

---

9. Disclaimer

This project was completed for educational purposes within an isolated, self-owned lab environment. Metasploitable2 is deliberately vulnerable and must never be exposed to untrusted networks. The techniques documented here are for authorized security testing and learning only. The author accepts no responsibility for misuse.

Author: Vansh Singh · ApexPlanet Cybersecurity & Ethical Hacking Internship